

CodeNova Business Website

Backend Requirements Document (BRD)

Version: 1.0 **Project:** CodeNova Business Website

Defines the server-side architecture, business logic, APIs, authentication, lead management, email, integrations and administrative backend required for the CodeNova business website.

1. Backend Objectives

- Provide secure APIs for public website forms and dynamic content.
- Store and manage leads, consultations, estimator requests, services, portfolio and blog content.
- Protect administrative operations with authentication and authorization.
- Support email, analytics, WhatsApp and optional calendar integrations.
- Provide a scalable foundation for future client portal and project management features.

2. Recommended Backend Stack

- Node.js/Next.js server routes or a dedicated Node.js/Express service.
- TypeScript recommended for type safety.
- PostgreSQL through Supabase.
- Supabase Auth or equivalent secure authentication.
- Zod or equivalent server-side schema validation.
- Resend/Brevo for transactional email.
- Vercel or equivalent managed hosting.

3. Backend Modules

- Authentication and authorization.
- Lead management.
- Consultation booking.
- Project estimator.
- Services management.
- Portfolio/case studies.
- Blog/CMS.
- Testimonials.
- Site settings.
- Email notifications.
- Analytics event handling where server-side processing is needed.
- Audit/activity logging.

4. Lead Management Logic

- Create lead from contact form.

- Capture service, budget, country, source and project description.
- Default status = New.
- Prevent duplicate spam submissions using rate limiting and optional CAPTCHA.
- Allow authorized admins to update status, notes and assignment.
- Record created_at and updated_at timestamps.
- Optional future statuses: Contacted, Qualified, Proposal Sent, Negotiation, Won, Lost.

5. Authentication & Authorization

- Public endpoints require no account unless business requirements change.
- Admin endpoints require authenticated sessions.
- Use role-based authorization.
- Verify permissions server-side on every protected operation.
- Use secure password hashing if passwords are managed directly.
- Support MFA for admins where provider capabilities allow.
- Invalidate/reset sessions appropriately.

6. Core Business Logic

- Contact form: validate → sanitize → store → notify.
- Consultation: validate → store → optionally create calendar event → send confirmation.
- Estimator: validate selections → calculate indicative range → optionally store lead.
- Portfolio/blog: publish only records marked active/published.
- Admin changes: authorize → validate → mutate → record audit event where appropriate.

7. Email Service

- Internal lead notification.
- Visitor inquiry confirmation.
- Consultation confirmation.
- Optional proposal/follow-up templates.
- Use server-side API keys only.
- Handle provider failures without exposing provider credentials.

8. Integrations

- Supabase/PostgreSQL.
- Email provider.
- Google Calendar/Calendly optional.
- WhatsApp click-to-chat handled primarily by frontend.
- Google Analytics/Search Console primarily frontend/marketing integrations.
- Optional CRM integration in a later phase.

9. Error Handling

- Use structured JSON errors.
- 400 for invalid input.
- 401 for unauthenticated requests.
- 403 for unauthorized requests.
- 404 for missing resources.
- 409 for conflicts where applicable.
- 429 for rate-limit violations.
- 500/503 for server/provider failures.
- Never expose stack traces, secrets or database details to users.

10. Logging & Monitoring

- Log important server errors and security events.
- Do not log passwords, tokens or unnecessary personal data.
- Include request correlation IDs where practical.
- Monitor failed authentication, API errors, email failures and unusual traffic.
- Integrate an error-monitoring service if required.

11. Backend Acceptance Criteria

- All public forms have server-side validation.
- Admin APIs require authorization.
- Lead records are stored correctly.
- Email failures are handled gracefully.
- Rate limiting is active on abuse-prone endpoints.
- Secrets remain server-side.
- Automated tests cover critical business logic and protected routes.

Document Relationship

This document complements the CodeNova PRD, TRD, Security & Privacy Document and Frontend Requirements Document. Implementation should use the approved business information and actual production configuration rather than placeholders or unverified claims.